PARCOURS SÉCURITÉ RÉSEAU · LAB FORTIGATE

FortiGate — Fondamentaux

Politiques stateful, DMZ en least privilege et VIP (port forwarding)

FortiOS 7.4.12 VM (licence d'essai permanente) · GNS3 · Oumar Thiaw · 18 octobre 2026

Objectif et contraintes

Transposer sur FortiGate les labs pfSense #1 à #3 (règles stateful, segmentation DMZ, durcissement et NAT entrant) en un seul lab condensé. Résultat validé : trois zones, trois politiques, chaque comportement prouvé par un test et lu dans les logs.

> **Contrainte de la licence d'essai permanente (FortiOS 7.2.1 et plus)**
> 1 vCPU et 2 Go de RAM maximum, chiffrement faible uniquement, pas de services FortiGuard.
> **3 interfaces, 3 politiques de pare-feu et 3 routes au maximum.** L'implicit deny ne compte pas dans les 3.
> Conséquence : pas de politique LAN → DMZ dans ce lab (limite de licence, pas un choix de conception).

Topologie et adressage

```
Client WAN (Webterm .60) ─┐
                          ├─ Switch-WAN — NAT (passerelle 192.168.122.1)
FortiGate port1 / WAN ────┘   DHCP 192.168.122.x
FortiGate port2 / LAN = 192.168.1.1/24  — Switch-LAN — VPCS .20 + Webterm .50 + Cloud eth1 (PC .10)
FortiGate port3 / DMZ = 172.16.1.1/24   — Switch-DMZ — VPCS .10 + Webterm serveur .11
```

Interface	GNS3	Alias / rôle	Adressage	Accès admin
port1	Ethernet0	WAN / WAN	DHCP 192.168.122.x	ping http https ssh
port2	Ethernet1	LAN / LAN	192.168.1.1/24	ping http https ssh
port3	Ethernet2	DMZ / DMZ	172.16.1.1/24	**ping uniquement**

Budget de politiques (3/3 utilisées)

#	Nom	Entrée → Sortie	Service	NAT	Équivalent pfSense
1	LAN-to-WAN	port2 → port1	ALL	Oui (SNAT)	Lab #1 : règle allow LAN + NAT sortante auto
2	DMZ-to-WAN	port3 → port1	web_ports	Oui (SNAT)	Lab #3 : alias web_ports (80/443/53)
3	WAN-to-DMZ-Web	port1 → port3	HTTP	Non	Lab #3 : Port Forward WAN:80 → .11:80
0	Implicit Deny	tout le reste	—	—	Default deny

Partie 1 — Implicit deny, LAN → WAN et stateful

1.1 Constater l'implicit deny

Sans aucune politique, le ping du VPCS LAN (192.168.1.20) vers 8.8.8.8 échoue. Le refus n'est visible qu'après avoir activé la journalisation : **Politique et objets → Politique de pare-feu** → clic droit sur **Implicit Deny** → **Journaliser les violations**. Le log apparaît dans **Journal et rapport → Trafic transféré** avec l'action Deny et la politique 0.

1.2 Politique LAN-to-WAN

Interface entrante port2, sortante port1, source et destination all, service ALL, action ACCEPT, **NAT activée** (adresse de l'interface sortante), journalisation **Toutes les sessions**. Équivalent CLI :

```
config firewall policy
    edit 1
        set name "LAN-to-WAN"
        set srcintf "port2"
        set dstintf "port1"
        set srcaddr "all"
        set dstaddr "all"
        set action accept
        set schedule "always"
        set service "ALL"
        set nat enable
        set logtraffic all
    next
end
```

Parallèle pfSense

pfSense crée une règle « Default allow LAN to any » à l'installation et journalise le blocage par défaut d'office. La FortiGate part de zéro : aucune politique, refus non journalisé tant qu'on ne l'active pas.
Sur pfSense, la NAT sortante est séparée (Firewall → NAT → Outbound, mode automatique). Sur FortiGate, en mode NAT par défaut, la NAT source se coche **dans la politique**.

1.3 Tests et stateful

Test (VPCS LAN)	Résultat	Vérification
`ping 8.8.8.8` sans politique	Bloqué	Log Deny, politique 0
`ping 8.8.8.8`	OK	Log Accept, politique 1
`ping google.com`	OK	DNS + ICMP via politique 1

Pourquoi les réponses reviennent sans politique WAN → LAN : la politique n'est évaluée qu'au premier paquet. Si elle autorise, la FortiGate crée une **session** décrivant les deux sens (`orgin` et `reply`). Les paquets retour correspondent à cette session et passent sans nouvelle évaluation. La NAT ne crée aucune politique : elle est enregistrée dans la session (`act=snat`).

```
diagnose sys session filter dst 8.8.8.8
diagnose sys session list          # repérer policy_id=1, act=snat, orgin/reply
```

Parallèle pfSense

La session FortiGate correspond à la **State Table** (Diagnostics → States).

Partie 2 — DMZ et least privilege

2.1 Interface port3

Alias DMZ, rôle DMZ, 172.16.1.1/24, accès administratif **PING uniquement** : un serveur DMZ compromis ne doit pas pouvoir atteindre l'interface d'administration du firewall. Le rôle d'interface ne crée aucune règle.

2.2 Groupe de services et politique DMZ-to-WAN

Politique et objets → Services → Créer → Groupe de services `web_ports` = HTTP + HTTPS + DNS (le service DNS couvre déjà TCP et UDP 53). Politique 2 : port3 → port1, service `web_ports`, NAT activée, journalisation complète.

> **Parallèle pfSense**
> Le groupe de services remplace l'alias de ports `web_ports` (Firewall → Aliases → Ports). Sur FortiGate, le service porte aussi le protocole.

2.3 Tests depuis le VPCS DMZ (172.16.1.10)

Le VPCS teste des ports TCP avec `-P 6` (TCP) et `-p` (port).

Test	Commande	Résultat	Raison
HTTPS sortant	`ping 1.1.1.1 -P 6 -p 443`	OK	HTTPS dans web_ports
DNS + HTTP	`ping google.com -P 6 -p 80`	OK	DNS puis HTTP autorisés
ICMP sortant	`ping 8.8.8.8`	Bloqué	ICMP absent de web_ports
DMZ → LAN	`ping 192.168.1.20`	Bloqué	Aucune politique : implicit deny

Partie 3 — VIP (port forwarding) WAN → DMZ

3.1 Serveur web en DMZ (Webterm 172.16.1.11)

Le contenu de la réponse est placé dans un fichier, pour qu'aucune séquence `\r\n` ne transite par socat :

```
printf 'HTTP/1.1 200 OK\r\nContent-Type: text/plain\r\n\r\nDMZ server OK\n' > /tmp/page.txt
socat TCP-LISTEN:80,fork,reuseaddr SYSTEM:"cat /tmp/page.txt"
```

3.2 VIP et politique WAN-to-DMZ-Web

Objet	Paramètre	Valeur
VIP-DMZ-Web	Interface / IP externe	port1 / **0.0.0.0** (suit l'IP DHCP de port1)
	IP mappée	172.16.1.11
	Redirection de port	TCP 80 → 80
Politique 3	Entrée → sortie	port1 → port3
	Destination	**l'objet VIP**, pas l'IP 172.16.1.11
	Service / NAT	HTTP / **NAT désactivée** (le serveur voit l'IP réelle du client)

```
config firewall vip
    edit "VIP-DMZ-Web"
        set extip 0.0.0.0
        set extintf "port1"
        set mappedip "172.16.1.11"
        set portforward enable
        set extport 80
        set mappedport 80
    next
end
```

> **Parallèle pfSense — question classique d'entretien**
> pfSense : Port Forward et règle de filtrage sont deux objets distincts ; la règle vise l'**IP interne**, car le filtrage s'applique après la NAT.
> FortiGate : la politique vise l'**objet VIP**, qui porte lui-même la traduction de destination. Même résultat, logique différente.
> pfSense bloquait le client en 192.168.122.x (« Block private networks » sur le WAN). FortiGate n'a pas ce blocage par défaut.

3.3 Test

Depuis le Webterm client WAN (192.168.122.60) : `http://<IP de port1>` affiche **« DMZ server OK »**. Dans les logs, la session est acceptée par la politique 3 avec la destination traduite ; en CLI, `act=dnat`.

```
diagnose sys session filter dport 80
diagnose sys session list          # repérer act=dnat et la destination 172.16.1.11
```

Tableau de correspondance pfSense ↔ FortiGate

Notion	pfSense	FortiGate
Refus par défaut	Default deny, journalisé d'office	Implicit deny (politique 0), journalisation à activer
Autoriser LAN → Internet	Règle + NAT sortante automatique séparée	Politique avec case NAT
Stateful	State Table	Sessions (`diagnose sys session list`)
Least privilege	Alias de ports	Groupe de services
Segmentation DMZ → LAN	Règle block explicite	Absence de politique (implicit deny)
Publication d'un serveur	Port Forward + règle sur l'IP interne	VIP + politique sur l'objet VIP
Écriture des logs	Au premier paquet (si coché)	En fin de session (durée, volumes)
Diagnostic	States, Packet Capture	`diagnose debug flow`, `diagnose sniffer packet`
Administration d'interface	Anti-lockout, règles sur l'IP du firewall	`allowaccess` par interface

Troubleshooting et pièges rencontrés

Symptôme	Cause	Correction / réflexe
Seuls des logs Deny visibles alors que le ping passe	Filtre « Policy ID: 0 » resté actif dans la vue	Toujours vérifier les filtres d'une vue de logs vide
Log Accept absent juste après un ping	Log écrit à la fin de la session (environ 60 s pour ICMP)	Attendre puis rafraîchir, ou observer FortiView Sessions
`sh: 3: DMZ: not found`, page blanche	socat convertit `\r\n` avant le shell	Réponse HTTP dans un fichier, `SYSTEM:"cat /tmp/page.txt"`
Page blanche mais connexion établie	Le réseau fonctionne, c'est l'application qui échoue	Lire les logs : session acceptée = VIP et politique bonnes
Conflit d'IP côté WAN	Les nœuds NAT des projets GNS3 partagent le même réseau	Client WAN en .60 (le lab pfSense utilise .50)
PC sans accès à la GUI	Cloud branché sur eth0 au lieu de eth1	Sur cette GNS3 VM, eth1 = host-only VMnet1

Aide-mémoire diagnostic

```
# Quelle politique décide pour un paquet ?
diagnose debug flow filter addr 8.8.8.8
diagnose debug flow show function-name enable
diagnose debug flow trace start 10
diagnose debug enable
#   ... générer le trafic, chercher "Allowed by Policy-N" ou "Denied by forward policy check (policy 0)"
diagnose debug disable
diagnose debug reset

# Les paquets arrivent-ils sur l'interface ?
diagnose sniffer packet port2 "icmp or arp" 4

# Configuration d'une politique
show firewall policy 1
```

Questions d'entretien

- **Pourquoi le trafic retour passe-t-il sans politique inverse ?** Parce que la FortiGate est stateful : la politique est évaluée au premier paquet, puis la session autorise les deux sens.
- **Quelle destination met-on dans une politique de port forwarding ?** L'objet VIP, qui déclenche la DNAT ; sur pfSense, la règle vise l'IP interne.
- **Pourquoi désactiver la NAT sur la politique WAN → DMZ ?** Pour que le serveur voie l'IP réelle du client (logs, traçabilité, filtrage applicatif).
- **Comment savoir quelle politique bloque un flux ?** `diagnose debug flow` donne le numéro de la politique qui décide, y compris la politique 0.

Sauvegardes

- Snapshots GNS3 : `FGT-base-licence-OK` (installation) et `FGT-lab-fondamentaux-OK` (fin de ce lab).
- Fichier de configuration FortiGate : menu admin → Configuration → Sauvegarde (`.conf`). Restaurable sans toucher à la licence.
- Pour le Lab #4 IPsec pfSense ↔ FortiGate : libérer le budget en supprimant les politiques DMZ (2 politiques nécessaires pour le tunnel).